The 25 Sources & Attribution

Every data source, its category, its checks, and the deliberate exclusions.

Exposure-Check-OSINT v1.7.0 · Apache-2.0 · self-hosted · keyless · no AI · github.com/RanaKhan77/Exposure-Check-OSINT

Every source below is free, keyless (no API key, no account), read-only, and queried over HTTPS or plain DNS. Per-source enable/disable lives on the Settings page. Attribution and limits are listed honestly — if a source is down, its card shows unavailable and the check continues (per-source isolation).

#	Source	Category	Checks	Notes
1	HudsonRock	stealer	email	Stealer-log infections linked to the email (counts + machine info only; no raw cookies)
2	XposedOrNot	breach	email	Which breaches contain the email (names, dates, record counts)
3	ProxyNova COMB	breach	email, phone	11B+ credential-pair COMB corpus association (masked, credential lines never stored)
4	HIBP Pwned Passwords	breach	password	k-anonymity: only the 5-char SHA-1 prefix leaves this server; suffix matching happens in YOUR browser
5	Mailcheck	email	email	Domain deliverability + disposable classification
6	Gravatar	profile	email	Public avatar + profile existence
7	Disposable Email Domains list	email	email	One-time/temp provider domain flag
8	Disify	email	email	Disposable/validity signal
9	Kickbox Open	email	email	Disposable signal (open endpoint)
10	FachaTemp	email	email	Temp-provider domain signal
11	Presend	email, phone	email, phone	Deliverability + phone lookups
12	GitHub public search	profile	email, username	Public code/profile associations
13	Maigret corpus (200 sites)	profile	username	Username registered on N of 200 popular platforms — rendered as the platform logo grid. Corpus: maigret (MIT) + WhatsMyName (CC BY-SA 4.0), differential-verified
14	Bluesky (AT Protocol)	profile	username	Handle/profile existence
15	Hacker News (Firebase)	profile	username	Public HN account existence + karma
16	PhoneValidity	infra	phone	Country, line type, validity — no external call
17	Shodan InternetDB	infra	ip	Open ports + services on the IP
18	ipapi.is	infra	ip	VPN/proxy/hosting classification
19	Bot-CIDR attribution	infra	ip	Is the IP a known crawler/bot network — offline, no external call
20	crt.sh — Certificate Transparency	infra	domain	Historical subdomains that ever obtained a TLS certificate — counts + first 40 names
21	RDAP — Domain Registration Records	infra	domain	Registrar, registration/expiry dates, status — registration age as a fraud/trust signal
22	LeakLens	breach	phone, username	Breach-registry search for phone numbers and usernames; honest `unavailable` when upstreams degrade
23	DNS Blocklists (Spamhaus ZEN, SpamCop, Barracuda)	reputation	ip	Is the IP listed for spam/abuse? Each zone is verified answering via its permanently-listed test address (127.0.0.2) before its verdict counts — public/open-resolver refusals and empty answers degrade to `not assessed`, never a fake clean. PBL-only policy listings (normal for residential IPs) report severity `low`; abuse listings `medium`. Zone probes are memoized per worker process + results cached 30 min. Requires a normal (non-public) resolver: public resolvers like 8.8.8.8/1.1.1.1 are refused by Spamhaus — run a local/system resolver

#	Source	Category	Checks	Notes
24	Keybase	profile	username	Identity-graph pivot: one keyless lookup returns the account's deliberately-public verified proofs — Twitter, GitHub, Reddit, HackerNews, DNS domains, PGP fingerprint. A bare account is a low-severity footprint; 3+ verified links is a real deanonymization surface (medium). Verified proofs (state=1) only — unverified claims never count
25	GitHub Commit Author Emails	profile	username	Which real email addresses the account authored public commits with (masked, e.g. `t***s@...`). Addresses are MASKED; noreply-only accounts report good hygiene; carries the PROBABLE caveat the adoption review required — git author fields are spoofable, so a match is evidence of exposure, not proof

Per-source endpoints (API paths) are listed in docs/SOURCES.md in the repository — the table above keeps this PDF readable at print size.

Display images

Platform favicons and Gravatar avatars are fetched once per platform by the in-repo OsintLogoService (24h negative cache, 5s budget per fetch) and served from /osint-logo/{key} and /osint-avatar/gravatar/{hash}. A missing image falls back to a letter tile — never blocks a result.

Deliberately NOT in the Community Edition

- GrayHatWarfare — bucket search (the hosted 2mny.com version uses an owner API key; the CE stays 100% keyless)
- Domain / website checks — that is the job of the Website Vulnerability Scanner CE (202 modules). Domain intelligence lives in the main scanner engine instead: the hosted platform's org_breach_history module reports an organization's documented data-breach history from the LeakLens registry — leaklens.org, free for non-commercial use, attribution required and given. The CE stays personal-identifiers-only.
- holehe binary — the hosted product runs it internally (GPLv3, run-not-redistributed); the CE stays license-clean without it
- The ~120-platform linked-account probe — v1.1 roadmap: it needs a companion headless-browser microservice (the same one the hosted product runs); ships as an optional Docker add-on, never as a hard dependency
- Telegram / WhatsApp lookups — require bot keys and risk account bans (fail the keyless + safe-to-operate bar)

Adding a source

Implement App\Modules\Osint\Sources\OsintSource (two methods: requests() + parse()), register the class in OsintCheckService::SOURCES, add a row to docs/SOURCES.md. The contract is documented inline in app/Modules/Osint/Sources/OsintSource.php — including the non-negotiable ethical rules (never return plaintext credentials, never return third-party personal data, always degrade to unavailable on failure).